Lab 7: Access Control

Houda Toudali

Information Security

Part 1 : Discretionary Access Control (DAC)

2.2 Guided experiment

```
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7$ mkdir -p DAC_Lab
cd DAC_Lab
touch report.txt
ls -l report.txt
-rwxrwxrwx 1 wwwto wwwto 0 Nov 10 11:18 report.txt
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ chmod 740 report.txt
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ ls -l report.txt
-rwxrwxrwx 1 wwwto wwwto 0 Nov 10 11:18 report.txt
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo groupadd accounting
[sudo: authenticate] Password:
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo chown root:accounting report
.txt
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ ls -l report.txt
-rwxrwxrwx 1 wwwto wwwto 0 Nov 10 11:18 report.txt
```

Challenge 1 : Confidential Documents

```
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo chmod 640 /company/finance/budget.txt
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ ls -ld /company/finance
drwxr-x--- 2 root accounting 4096 Nov 10 11:27 /company/finance
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ ls -l /company/finance
ls: cannot open directory '/company/finance': Permission denied
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ ls -l /company/finance
ls: cannot open directory '/company/finance': Permission denied
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo ls -ld /company/finance
drwxr-x--- 2 root accounting 4096 Nov 10 11:27 /company/finance
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo ls -l /company/finance
total 0
-rw-r----- 1 root accounting 0 Nov 10 11:27 budget.txt
```

q1,2,3,4,5

Q6. Directory 750 and file 600

No , A member of `accounting` can enter the directory , but cannot read a file with permission `600`,because only the owner has access to that file.

```
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo chmod 600 /company/finance/budget.txt
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo ls -l /company/finance/budget.txt
-rw------- 1 root accounting 0 Nov 10 11:27 /company/finance/budget.txt
```

The file changed to permission 600.

Part 2 : Mandatory Access Control (MAC)

3.3 Practical exploration: SELinux

`sestatus` reported that SELinux was disabled.

```
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sestatus
SELinux status:                 disabled
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ ls -Z
? report.txt  ? screenshots
```

Challenge 2 : Military Information System

Q1. The read-access matrix

User	Document_A (Secret)	Document_B (Confidential)	Document_C (Public)
Alice (Secret)	Allow	Allow	Allow
Bob (Confidential)	Deny	Allow	Allow
Charlie (Public)	Deny	Deny	Allow

Q2. Bob reads Document_A

Denied. Bob has Confidential clearance and Document_A is Secret. This violates the *No Read Up* rule.

Q3. Alice writes to Document_C

Denied. Alice has Secret clearance and Document_C is Public. This violates the *No Write Down* rule.

Q4. How does Bell–LaPadula prevents leakage

No Read Up blocks users from reading higher-classified information. *No Write Down* stops sensitive information from being written to a lower classification.

Q5.

Access is not necessarily granted . MAC checks the security policy , while DAC checks file ownership and permissions . A request can still be denied by Linux permissions even when the MAC clearance is sufficient .

Part 3 : Role-Based Access Control (RBAC)

4.2 Guided experiment

```
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ groups alice
alice : alice users developers
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ groups bob
bob : bob users viewers
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ groups charlie
charlie : charlie users administrators
```

I configured `/company/source` for the developers group with permission `770`, and `/company/reports` for the viewers group with permission `750`.

Challenge 3 : Enterprise Access Management

Q1. I created groups and assign users

Q2. I Configured permissions for both directories

Q3. Does the initial configuration satisfy the policy?

No . Developers could not read reports, and the administrators group had no access to either directory.

Q4. we correct the missing permissions

I added ACL entries: `administrators:rwx` on both directories and `developers:r-x` on reports.

Role	Source code	Reports
Developer	Read / Write	Read
Viewer	No access	Read
Administrator	Full access	Full access

```
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo setfacl -m g:administrators:rwx /company/source
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo setfacl -m g:developers:rx /company/reports
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo setfacl -m g:administrators:rwx /company/reports
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ getfacl /company/reports
getfacl: Removing leading '/' from absolute path names
# file: company/reports
# owner: root
# group: viewers
user::rwx
group::r-x
group:administrators:rwx
group:developers:r-x
mask::rwx
other::---
```

ACL entries for the reports directory.

Alice could create files in `source` but not `reports`. Bob could read reports but not source code. Charlie could create and list files in both directories.

```
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo -u alice touch /company/source/alice_test.txt
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo -u alice ls /company/source
alice_test.txt
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo -u alice ls /company/reports
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo -u alice test -w /company/reports && echo "WRITE ALLOWED" || echo "WRITE DENIE
D"
WRITE DENIED
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$
```

Developer access test using Alice.

```
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo -u charlie touch /company/source/charlie_test.txt
sudo -u charlie touch /company/reports/charlie_test.txt
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$ sudo -u charlie ls /company/source
sudo -u charlie ls /company/reports
alice_test.txt  charlie_test.txt
charlie_test.txt
wwwto@houda:/mnt/c/Users/wwwto/Desktop/S3_CI2/Information Security/Labs/Lab 7/DAC_Lab$
```

Administrator access test using Charlie.

Part 4 : Attribute-Based Access Control (ABAC)

Challenge 4 : Banking Access Policy

Q1. Determine whether each request is granted or denied

User	Time	Decision
Alice	10:00	Grant
Bob	11:00	Deny
Charlie	14:00	Deny
David	22:00	Deny

Q2. Identify the attribute responsible for each denial

User	Reason
Bob	Department mismatch (HR versus Finance)
Charlie	Insufficient clearance (Public versus Secret)
David	Request outside allowed hours (22:00)

Q3. Alice requests access to an HR document

Denied. Alice works in Finance, so the department does not match the HR document.

Q4. David requests access at 17:00

Yes, the decision changes to Grant. His department and clearance match, and 17:00 is within the allowed period.

Q5. Why is ABAC more flexible than RBAC?

RBAC uses fixed roles. ABAC can also check the department, document classification, action and time of a request, so access can depend on the situation.